



CIBERSEGURIDAD EN ENTORNOS DE LAS TECNOLOGÍAS DE LA INFORMACIÓN

Hacking Ético

TEMA 1

UT01.- Hacking ético, conceptos y herramientas para detección de vulnerabilidades
Alberto Diéguez Álvarez

¿Qué te pedimos que hagas?	3
Apartado 1: Diseñar el plan de auditoría	3
• Justificar la elección de cada auditoría elegida.	3
• Justificar los activos incluidos en cada auditoría.....	3
• Indicar en cada caso el tipo de auditoría dependiendo del enfoque, origen e información proporcionada y justifica cada caso.....	3
• Indica el objetivo que quieres conseguir con la elección de cada tipo de auditoría.....	3
Apartado 2: Organiza las fases de la auditoría.....	5
• Utiliza un calendario o línea temporal para indicar cuándo se realizaría cada fase y el tiempo estimado.....	5
• Indica los objetivos a cumplir en cada fase.....	5
• Justifica para cada auditoría si se contemplan reuniones de seguimiento o no, en caso afirmativo cada cuánto tiempo.	5
Apartado 3: Presentación y valoración de vulnerabilidades.	7
• Valoración de la vulnerabilidad especificando los grupos de métricas base y temporal. Además, indica el vector CVSS resultante, realizar capturas de pantalla de los valores indicados.	7
• Es muy importante justificar vuestra elección en los puntos del formulario CVSS.	7
• Justificar si es una vulnerabilidad que afecta al servidor o a los clientes.	7
• Las vulnerabilidades localizadas son las siguientes.....	7
Vulnerabilidad en el sistema de correo.....	8
Vulnerabilidad de inyección SQL.....	10
Vulnerabilidad de ejecución de código en un servidor FTP	11
Webgrafía:	13

¿Qué te pedimos que hagas?

Apartado 1: Diseñar el plan de auditoría

Teniendo en cuenta las premisas y restricciones indicadas por Teresa diseñar el plan de auditoría. Como mínimo tienes que plantear y explicar las siguientes cuestiones y razonar correctamente tu elección:

- Justificar la elección de cada auditoría elegida.
- Justificar los activos incluidos en cada auditoría.
- Indicar en cada caso el tipo de auditoría dependiendo del enfoque, origen e información proporcionada y justifica cada caso
- Indica el objetivo que quieres conseguir con la elección de cada tipo de auditoría.

Para la realización de este apartado puedes usar la siguiente tabla como referencia:

Nombre de la Auditoría	Justificación de la Auditoría	Activo(s) y justificación	Enfoque (manual, automática, etc)	Origen (interna o externa)	Información proporcionada (tipo de caja)	Objetivo
Auditoría de ataques externos	Se realizan ataques desde internet para comprometer los servicios críticos y para comprobar la resistencia de la organización	Servidores web. Nos dicen que tienen 20 activos expuestos en internet y que 3 de ellos son críticos. También podemos tratar, servidores de correo, acceso VPN...	Pruebas automáticas: No requieren apearas iteración del auditor y se trata de identificar el mayor número de vulnerabilidades consumiendo poco tiempo.	Externa : Se realizará a desde Internet.	Caja negra: Las pruebas se realizan sin conocimiento sobre la infraestructura a auditar.	Detectar problemas, configuraciones, mapeo de servicios, versiones...
Auditoría de activos críticos	Tras un barrido general, nos centramos en los 3 activos críticos.	3 activos críticos expuestos, tendrían prioridad por el impacto que tendría sobre la empresa.	Manual: tenemos como objetivo hacer un estudio minucioso sobre esos activos.	Externa , ya que lo haríamos desde internet	Caja negra: Si lo hacemos como un atacante externo. Caja gris: si nos cedieran alguna cuenta de prueba.	Comprobar la robustez de los activos, si se pueden comprometer, escalar privilegios...
Prueba de red Interna	En esta auditoría nos centramos en analizar riesgos de escalada interna de privilegios interna, ataques internos...	Servidores, archivos y dispositivos de la red, así como pruebas de ingeniería social...	Manual: Haríamos un escaneo interno intenso, revisar configuraciones y las pruebas físicas que se nos permita.	Interna: Ya que lo haríamos desde la red interna	Caja Blanca: Ya que tenemos acceso a documentación, configuraciones ...	Detectar privilegios no deseados, evaluar procesos, vulnerabilidades internas...

Apartado 2: Organiza las fases de la auditoría

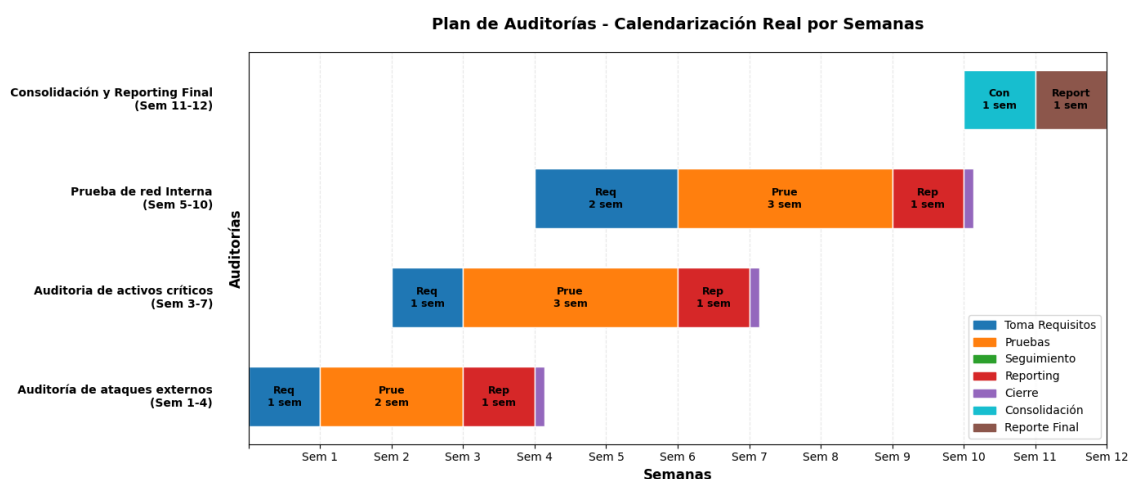
Una vez has planteado las auditorías que realizarías, es necesario que indiques para cada una de ellas un calendario (o timeline) en el que se refleje los hitos de cada una de las fases con estimaciones de tiempo:

- Utiliza un calendario o línea temporal para indicar cuándo se realizaría cada fase y el tiempo estimado.
- Indica los objetivos a cumplir en cada fase.
- Justifica para cada auditoría si se contemplan reuniones de seguimiento o no, en caso afirmativo cada cuánto tiempo.

Para la realización de este apartado puedes usar la siguiente tabla como referencia:

Auditoría	Duración	Fases				
		Toma de requisitos	Realización de pruebas	Seguimiento de pruebas	Reporting	Cierre de auditoría
Auditoría de ataques externos	4 semanas	Toma de requisitos	Realización de pruebas	Seguimiento de pruebas	Reporting	Cierre de auditoría
		1 semana	2 semanas	Reuniones semanales	1 semana	1 día
Auditoría de activos críticos	5 semanas	Toma de requisitos	Realización de pruebas	Seguimiento de pruebas	Reporting	Cierre de auditoría
		1 semana	3 semanas	Reuniones cada 2 semanas	1 semana	1 día
Prueba de red Interna	6 semanas	Toma de requisitos	Realización de pruebas	Seguimiento de pruebas	Reporting	Cierre de auditoría
		2 semana	3 semanas	Reuniones semanales	1 semana	1 día

https://colab.research.google.com/drive/1aKu6YO5MtCvZAiBAH_01w9QJlzHYWR0E?usp=sharing



NOTA: Se debe indicar la temporalización de cada una de las fases de la auditoría.

Haciendo un pequeño resumen:

Auditoría de ataques externos

- **Primera semana:** Firmar acuerdos, recopilar información, establecer reglas...
- **Semanas 2 y 3:** Escaneo automático de vulnerabilidades, pruebas de explotación, escaneo de configuraciones...
- **Semana 4:** Documentar y elaborar recomendaciones.

Auditoría de activos críticos

- **Semana 3:** Identificar aplicaciones, definir casos de uso...
- **Semanas 4, 5 y 6:** Pruebas de autenticación, análisis de configuraciones de email, pruebas automáticas y manuales...
- **Semana 7:** Documentar y elaborar recomendaciones.

Prueba de red interna

- **Semana 5 y 6:** Mapeo de la red interna, obtención de credenciales...
- **Semanas 7, 8 y 9:** Escaneo de vulnerabilidades internas, análisis de configuración y políticas de acceso.
- **Semana 10:** Documentar y elaborar recomendaciones.

Consolidación y Reporte final

- **Semana 11:** Conclusión, consolidar todos los datos obtenidos.
- **Semanas 12:** Reporte final, y documentación a presentar.

Apartado 3: Presentación y valoración de vulnerabilidades.

En este caso nos ponemos en el lado de los auditores y tenemos que analizar siguientes vulnerabilidades que se han localizado durante las pruebas. Para cada una de ellas hay que completar la siguiente descripción.

- Valoración de la vulnerabilidad especificando los grupos de métricas base y temporal. Además, indica el vector CVSS resultante, realizar capturas de pantalla de los valores indicados.
- Es muy importante justificar vuestra elección en los puntos del formulario CVSS.
- Justificar si es una vulnerabilidad que afecta al servidor o a los clientes.
- Las vulnerabilidades localizadas son las siguientes.
 - Una vulnerabilidad en el sistema de correo de la compañía que permite tomar el control del servidor y acceder a los mensajes de correo de cualquier usuario, también puedes enviar correos electrónicos suplantando la identidad de los usuarios. El servidor de correo se encuentra expuesto en internet. La vulnerabilidad presenta tanto un exploit público accesible desde exploit-db como un parche propuesto por el fabricante.
 - Una vulnerabilidad de inyección SQL en la que se pueden consultar datos de otras Bases de Datos como la Base de Datos de Contabilidad. El servidor web está expuesto en internet, pero se requiere de un usuario para el acceso a la funcionalidad vulnerable. No es una vulnerabilidad conocida, el auditor la localizó en tiempo de auditoría.
 - Una vulnerabilidad de ejecución remota de código en un servidor FTP en la red interna de la organización. El servicio FTP se estaba ejecutando con privilegios del sistema (puede realizar cualquier acción en el sistema). Además, el acceso al servidor permite acceder a una subred de administración que no se encuentra accesible desde la red LAN de usuarios. Existe un parche público para corregir la vulnerabilidad. No hay exploit público, pero sí una prueba de concepto que el auditor ha tenido que modificar para poder explotar de manera correcta la vulnerabilidad.

Las métricas base son:

- Attack Vector (AV) / Vector de ataque
- Attack Complexity (AC) / Complejidad de ataque
- Privileges Required (PR) / Privilegios requeridos
- User Interaction (UI) / Interacción del usuario
- Scope (S) / Alcance
- Confidentiality (C) / Confidencialidad
- Integrity (I) / Integridad
- Availability (A) / Disponibilidad

Las métricas temporales son:

- Exploit Code Maturity (E) / Madurez del código de explotación
- Remediation Level (RL) / Nivel de remediación
- Report Confidence (RC) / Confianza en el informe

Vulnerabilidad en el sistema de correo

➤ Métricas base:

The screenshot displays the CVSS calculator interface. On the left is a navigation menu with links like 'Specification Document', 'User Guide', 'Examples', and 'Frequently Asked Questions'. The main area shows the 'Base Score' calculation with various metrics: Attack Vector (AV) set to Network (N), Attack Complexity (AC) set to Low (L), Privileges Required (PR) set to None (N), User Interaction (UI) set to None (N), Scope (S) set to Unchanged (U), Confidentiality (C) set to High (H), Integrity (I) set to High (H), and Availability (A) set to High (H). The resulting Base Score is 9.8 (Critical). Below this, the 'Vector String' is shown as CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H/RL:O/RC:C. At the bottom, the 'Temporal Score' is 9.4. On the right side of the interface, there is a user profile for 'ALBERTO DIEGUEZ ALVAREZ' with a profile picture, a 'Editar perfil' button, and personal information including email 'a.dieguez.alvarez@gmail.com'. Below the profile, there are sections for 'Detalles del curso' (listing 'Análisis Forense', 'Informático', 'Bastionado de Redes y Sistemas', 'Hacking Ético', 'Incidentes de Ciberseguridad', and 'Normativa de Ciberseguridad') and 'Actividad de accesos' (showing 'Primer acceso al sitio' on November 13, 2024, and 'Último acceso al sitio' on November 16, 2025).

- **Attack Vector (AV) / Vector de ataque:**
 - **Valor:** Network
 - **Justificación:** El servidor es accesible desde internet, y la vulnerabilidad se puede explotar desde una red interna o externa.
- **Attack Complexity (AC) / Complejidad de ataque:**
 - **Valor:** Low
 - **Justificación:** La vulnerabilidad presenta tanto un exploit público accesible desde exploit-db.
- **Privileges Required (PR) / Privilegios requeridos:**
 - **Valor:** None
 - **Justificación:** No se especifica la necesidad de credenciales.
- **User Interaction (UI) / Interacción del usuario:**
 - **Valor:** None
 - **Justificación:** No se especifica la necesidad de interacción del usuario.
- **Scope (S) / Alcance:**
 - **Valor:** Unchanged
 - **Justificación:** Afecta a un componente.
- **Confidentiality (C) / Confidencialidad:**
 - **Valor:** High

- **Justificación:** Acceso a los mensajes de correo de cualquier usuario.
- **Integrity (I) / Integridad**
 - **Valor:** High
 - **Justificación:** Puedes enviar correos electrónicos suplantando la identidad de los usuarios.
- **Availability (A) / Disponibilidad**
 - **Valor:** High
 - **Justificación:** Permite tomar el control del servidor.

➤ Métricas Temporales:

The screenshot displays a security dashboard with two main score sections: Temporal Score and Environmental Score, both rated 9.0 (Critical).

Temporal Score (9.0 Critical):

- Exploit Code Maturity (E):** Not Defined (X), Unproven (U), Proof-of-Concept (P), Functional (F), **High (H)**.
- Remediation Level (RL):** Not Defined (X), **Official Fix (O)**, Temporary Fix (T), Workaround (W), Unavailable (U).
- Report Confidence (RC):** Not Defined (X), Unknown (U), Reasonable (R), **Confirmed (C)**.

Environmental Score (9.0 Critical):

- Confidentiality Requirement (CR):** Not Defined (X), Low (L), Medium (M), High (H).
- Integrity Requirement (IR):** Not Defined (X), Low (L), Medium (M), High (H).
- Modified Attack Vector (MAV):** Not Defined (X), Network, Adjacent Network, Local.
- Modified Attack Complexity (MAC):** Physical, **Help**.

Right Sidebar:

- User:** ALBERTO DIEGUEZ ALVAREZ (Edit profile)
- Información Personal:** Dirección de correo: a.dieguez.alvarez@gmail.com
- Detalles del curso:**
 - Perfiles de curso:** Análisis Forense Informático (25-26), Bastionado de Redes y Sistemas (25-26), Hacking Ético (25-26), Incidentes de Ciberseguridad (25-26), Normativa de Ciberseguridad (25-26).
- Actividad de accesos:**
 - Primer acceso al sitio:** miércoles, 13 de noviembre de 2024, 15:15 (1 año 3 días)
 - Último acceso al sitio:** domingo, 16 de noviembre de 2025, 21:38 (50 segundos)

- **Exploit Code Maturity (E) / Madurez del código de explotación:**
 - **Valor:** High
 - **Justificación:** El exploit es público en exploit-db.
- **Remediation Level (RL) / Nivel de remediación:**
 - **Valor:** Oficial Fix
 - **Justificación:** Hay parche oficial.
- **Report Confidence (RC) / Confianza en el informe:**
 - **Valor:** Confirmed
 - **Justificación:** La vulnerabilidad está confirmada y tiene un parche disponible.

Vulnerabilidad de inyección SQL

➤ Métricas base:

calculator (including its design and an XML representation for CVSS v3.1).

Base Score 7.6 (High)

Attack Vector (AV)
Network (N) Adjacent (A) Local (L) Physical (P)

Attack Complexity (AC)
Low (L) High (H)

Privileges Required (PR)
None (N) Low (L) High (H)

User Interaction (UI)
None (N) Required (R)

Scope (S)
Unchanged (U) Changed (C)

Confidentiality (C)
None (N) Low (L) High (H)

Integrity (I)
None (N) Low (L) High (H)

Availability (A)
None (N) Low (L) High (H)

Vector String
CVSS3.1/AV:N/AC:L/PR:L/UI:R/S:C/C:H/L/A:N/E:H/R:L/O:R/C

Temporal Score 7.3 (Help)

Exploit Code Maturity (E)

Alberto Dieguez Alvarez
Edit profile

Información Personal
Dirección de correo: a.dieguez.alvarez@gmail.com

Detalles del curso
Perfiles de curso
Análisis Forense Informático (25-26)
Bestionado de Redes y Sistemas (25-26)
Hacking Ético (25-26)
Incidentes de Ciberseguridad (25-26)
Normativa de Ciberseguridad (25-26)

Actividad de accesos
Primer acceso al sitio: miércoles, 13 de noviembre de 2024, 15:15 (1 año 3 días)
Último acceso al sitio: domingo, 16 de noviembre de 2025, 21:38 (50 segundos)

- **Attack Vector (AV) / Vector de ataque:**
 - **Valor:** Network
 - **Justificación:** El servidor está expuesto a internet.
- **Attack Complexity (AC) / Complejidad de ataque:**
 - **Valor:** Low
 - **Justificación:** Es una técnica básica y estándar.
- **Privileges Required (PR) / Privilegios requeridos:**
 - **Valor:** Low
 - **Justificación:**
- **User Interaction (UI) / Interacción del usuario:**
 - **Valor:** Required
 - **Justificación:** Se requiere de un usuario para el acceso a la funcionalidad vulnerable.
- **Scope (S) / Alcance:**
 - **Valor:** Changed
 - **Justificación:** El acceso es cruzado entre BBDD.
- **Confidentiality (C) / Confidencialidad:**
 - **Valor:** High
 - **Justificación:** Se tiene acceso a datos muy sensibles, ya que son de contabilidad.
- **Integrity (I) / Integridad**
 - **Valor:** Low
 - **Justificación:** La vulnerabilidad es solo de consulta.
- **Availability (A) / Disponibilidad**
 - **Valor:** None
 - **Justificación:** No tiene efecto directo sobre el funcionamiento del servidor.

➤ Métricas Temporales:

Vector String -
CVSS3.1/AV:N/AC:L/PR:L/UI:R/SC:C/H:L/EA:N/E:U/RC:C

Temporal Score **7.0** (High)

Exploit Code Maturity (E)
 Not Defined (N) **Unproven (U)** Proof-of-Concept (P)
 Functional (F) High (H)

Remediation Level (RL)
Not Defined (N) Official Fix (O) Temporary Fix (T)
 Workaround (W) Unavailable (U)

Report Confidence (RC)
 Not Defined (N) Unknown (U) Reasonable (R)
Confirmed (C)

Environmental Score **7.0** (High)
 Confidentiality Requirement (CR) Modified Attack Vector (MAV) **Help**

ALBERTO DIEGUEZ ALVAREZ
 Editar perfil

Información Personal
 Dirección de correo: a.dieguez.alvarez@gmail.com

Detalles del curso
Perfiles de curso
 Análisis Forense Informático (25-26)
 Bastionado de Redes y Sistemas (25-26)
 Hacking Ético (25-26)
 Incidentes de Ciberseguridad (25-26)

Actividad de accesos
Primer acceso al sitio miércoles, 13 de noviembre de 2024, 15:15 (1 año 3 días)
Último acceso al sitio domingo, 16 de noviembre de 2025, 21:38 (50 segundos)

- **Exploit Code Maturity (E) / Madurez del código de explotación:**
 - **Valor:** Unproven
 - **Justificación:** No es una vulnerabilidad conocida, el auditor la localizó en tiempo de auditoría.
- **Remediation Level (RL) / Nivel de remediación:**
 - **Valor:** Not Defined
 - **Justificación:** No hay parche disponible.
- **Report Confidence (RC) / Confianza en el informe:**
 - **Valor:** Confirmed
 - **Justificación:** El auditor la localizó en tiempo de auditoría.

Vulnerabilidad de ejecución de código en un servidor FTP

➤ Métricas base:

Vulnerability Scoring System (CVSS-SIG)

- Calculator
- Specification Document
- User Guide
- Examples
- Frequently Asked Questions
- CVSS v4.0 Documentation & Resources
- CVSS v3.1 Archive
- CVSS v3.0 Archive
- CVSS v2 Archive
- JSON & XML Data Representations
- CVSS On-Line Training Course
- Identity & logo usage

Common Vulnerability Scoring System Version 3.1 Calculator

Hover over metric group names, metric names and metric values for a summary of the information in the official CVSS v3.1 Specification Document. The Specification is available in the list of links on the left, along with a User Guide providing additional scoring guidance, an Examples document of scored vulnerabilities, and notes on using this calculator (including its design and an XML representation for CVSS v3.1).

Base Score **7.6** (High)

Attack Vector (AV)
 Network (N) Adjacent (A) Local (L) Physical (P)

Attack Complexity (AC)
 Low (L) **High (H)**

Privileges Required (PR)
 None (N) Low (L) **High (H)**

User Interaction (UI)
 None (N) **Required (R)**

Scope (S)
 Unchanged (U) **Changed (C)**

Confidentiality (C)
 None (N) Low (L) **High (H)**

Integrity (I)
 None (N) Low (L) **High (H)**

Availability (A)
 None (N) Low (L) **High (H)**

Vector String -
CVSS3.1/AV:N/AC:H/PR:H/UI:R/SC:C/H:H/A:H/E:U/RC:C **Help**

ALBERTO DIEGUEZ ALVAREZ
 Editar perfil

Información Personal
 Dirección de correo: a.dieguez.alvarez@gmail.com

Detalles del curso
Perfiles de curso
 Análisis Forense Informático (25-26)
 Bastionado de Redes y Sistemas (25-26)
 Hacking Ético (25-26)
 Incidentes de Ciberseguridad (25-26)
 Normativa de Ciberseguridad (25-26)

Actividad de accesos
Primer acceso al sitio miércoles, 13 de noviembre de 2024, 15:15 (1 año 3 días)
Último acceso al sitio domingo, 16 de noviembre de 2025, 21:38 (50 segundos)

- **Attack Vector (AV) / Vector de ataque:**
 - **Valor:** Network
 - **Justificación:** El servidor FTP es accesible desde la red interna.
- **Attack Complexity (AC) / Complejidad de ataque:**
 - **Valor:** High
 - **Justificación:** El auditor ha tenido que modificar para poder explotar de manera correcta la vulnerabilidad.
- **Privileges Required (PR) / Privilegios requeridos:**
 - **Valor:** High
 - **Justificación:** El servicio FTP se estaba ejecutando con privilegios de sistema.
- **User Interaction (UI) / Interacción del usuario:**
 - **Valor:** Required
 - **Justificación:** Se necesita interacción del usuario.
- **Scope (S) / Alcance:**
 - **Valor:** Changed
 - **Justificación:** Permite acceso a la subred.
- **Confidentiality (C) / Confidencialidad:**
 - **Valor:** High
 - **Justificación:** Se consigue control total en el sistema, además de acceso a la subred.
- **Integrity (I) / Integridad**
 - **Valor:** High
 - **Justificación:** Es alta ya que tendría acceso a ficheros.
- **Availability (A) / Disponibilidad**
 - **Valor:** High
 - **Justificación:** Muchos ficheros podrían verse afectados.

➤ Métricas Temporales:

The screenshot displays a security dashboard with two main panels. The left panel shows temporal metrics for a specific vulnerability, while the right panel shows the user profile of Alberto Dieguez Alvarez.

Temporal Metrics Panel:

- Vector String:** CVSS3.1/AV:N/AC:H/PR:H/UI:R/SC:C/H:H/A:H/E:F/RL:O/RC:C
- Temporal Score:** 7.1 (High)
- Exploit Code Maturity (E):** Functional (F), High (H), Proof-of-Concept (P)
- Remediation Level (RL):** Official Fix (O), Temporary Fix (T), Workaround (W), Unavailable (U)
- Report Confidence (RC):** Confirmed (C), Unknown (U), Reasonable (R)
- Environmental Score:** 7.1 (High)
- Confidentiality Requirement (CR):** Modified Attack Vector (MAV)

User Profile Panel:

- Nombre:** ALBERTO DIEGUEZ ALVAREZ
- Información Personal:** Dirección de correo: a.dieguez.alvarez@gmail.com
- Detalles del curso:**
 - Perfiles de curso: Análisis Forense, Informático (25-26), Bastionado de Redes y Sistemas (25-26), Hacking Ético (25-26), Incidentes de Ciberseguridad (25-26), Normativa de
- Actividad de accesos:**
 - Primer acceso al sitio: miércoles, 13 de noviembre de 2024, 15:15 (1 año 3 días)
 - Último acceso al sitio: domingo, 16 de noviembre de 2025, 21:38 (50 segundos)

- **Exploit Code Maturity (E) / Madurez del código de explotación:**
 - **Valor:** Funcional
 - **Justificación:** Hay una prueba hecha por el auditor pero que ha tenido que modificar para poder explotarla.
- **Remediation Level (RL) / Nivel de remediación:**
 - **Valor:** Oficial Fix
 - **Justificación:** Existe un parche público para corregir la vulnerabilidad.
- **Report Confidence RC) / Confianza en el informe:**
 - **Valor:** Confirmed
 - **Justificación:** La vulnerabilidad está confirmada, pero hay parche público.

Webgrafía:

- <https://www.first.org/cvss/calculator/3-1>
- <https://nvd.nist.gov/vuln-metrics/cvss>
- https://en.wikipedia.org/wiki/Common_Vulnerability_Scoring_System
- <https://www.incibe.es/en/incibe-cert/blog/cvss-v40-steps-advanced-vulnerability-assessment>